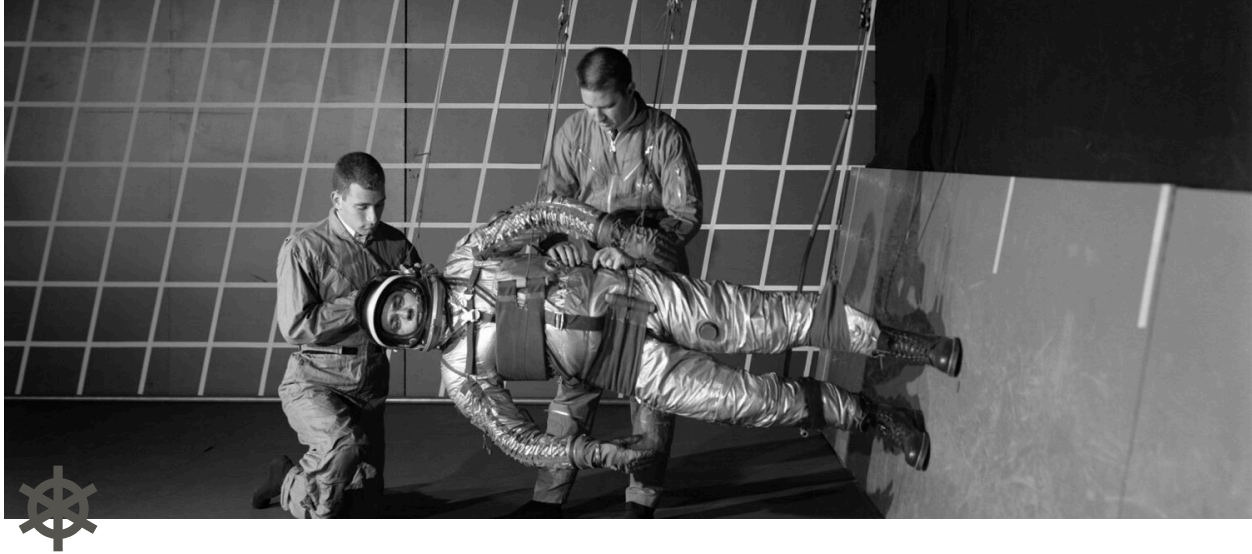




Security Gates in the “Road to Production”

Last Review: Jul 2025

Approved By : CISO

Next Review : Jul 2026

WHAT : The page describes the Security Gates that are part of the “Road to Production”

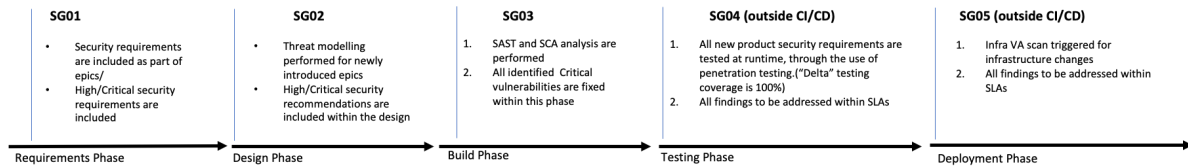
WHY :

- While a mature CI/CD by definition implies no frictions that prevents the continuous delivery & integration, getting there is a journey. Below security gates are intended to be the “friction” we need in order to ensure we are not only delivering fast, but also reliable/robust and it meets high security standards for our clients
- Closing findings from Internal audit

Security Gates

If the gates that are enforced are not met, then the code/feature should not move to the next stage, unless there is a Risk Acceptance from the duo PM-EM (which should not be the rule, but

only on exceptional basis)



Security Gate	Responsible team	How to enforce	Currently Enforced (Y/N)	Passing criteria/ expected result	Additional notes
SG01 - Requirements phase	Product	Product team will utilize the security requirements set created by Security team(here) to map them to the functional requirements of the feature/epic.	Y	All Must Have security requirements are included and passed to the Design phase	
SG02 - Design phase	Engineering Squads	All epics will require security sign-off at Design stage. (JIRA ticket)	Y	All High/Critical security recommendations are included within the design	
SG03 - Build phase	Engineering Squads	SAST and SCA scanning done on development branch	Y	Critical findings should be addressed before moving to production	
SG04 - Testing phase	Engineering Squads	Done asynchronous to the Dev sprints/ road to production	Y	-Validate the implementation of security Recommendations from Design phase -All security findings to be addressed within SLAs	
SG05 - Deployment phase	DevOps	Done asynchronous to the Dev	Y	All findings to be addressed within SLAs	

Security Gate	Responsible team	How to enforce	Currently Enforced (Y/N)	Passing criteria/ expected result	Additional notes
		sprints/ road to production			

SG01 - Requirements Phase

INPUT : New epic/story

OUTPUT : Security requirements attached to the Product Specs

Activities/ steps:

- Every new epic will have a new task : "Security requirements analysis" created by the PM
- The task will be conducted by PM with the help from EM, which will need to assess(through the Q&A from the security req [page](#)) all security requirements applicable for the epic/story.
- Task will be completed once there are no violation of security requirements moved further as past of the Design, or any existing violation were discussed with Security and addressed (including potential Risk Accepted)

SG02 - Design Phase

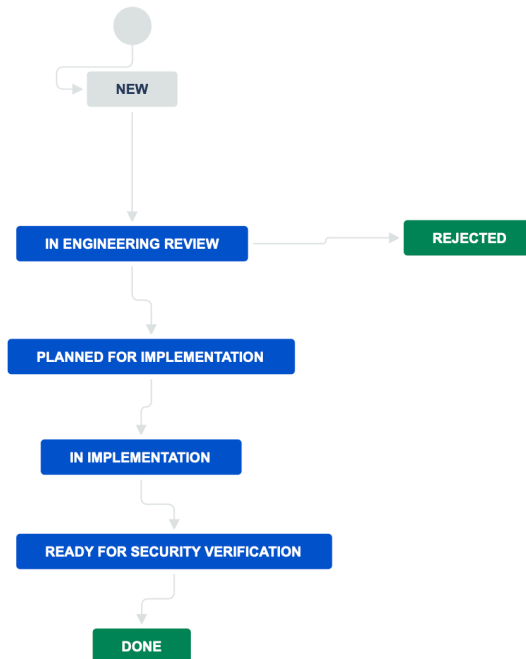
INPUT: Product Specs

OUTPUT: Engineering/technical specs with security requirements. Security Requirements tickets are created as part of the epic/story and moved to "Planned for Implementation" status.

Activities/ steps :

- Epic/story will be moved by PM into status " In Security Review" and assigned to Head of Security
- Security team will review the technical and design specs to validate the security requirements added during Requirements phase and add any missing security requirements.
- Security team will list/update all security requirements (categorized by : Mandatory and Recommend) in the Technical/Design specs.
- Depending on the severity/ impact of the new feature/flow, Security team may add as a Mandatory requirement, the need to do Penetration Testing before promoting to production (vs doing it after, asynchronous to CI/CD, as per SG04).
- Depending if the infrastructure is affected by the new feature, security team may require an infrastructure vulnerability assessment scanning (use of [Tenable.io](#) tool) before moving to production.

- For all Mandatory security requirement, the Security team will create (inside the squad JIRA project space) new Jira tickets of type = Security Requirements.
- The Duo will be responsible to complete the workflow(see below) of the SR tickets .
- To move to Build phase, all Security Requirements tickets need to be in “Planned for Implementation” status which means they are committed , from Duo side, for implementation



SG03 - Build Phase

INPUT: Finalized technical/design specs

OUTPUT: Built feature/flow as per the epic/story with no High or Critical security vulnerabilities raised and not solved. Security Requirements tickets moved into “Ready for Security Verification” status

Activities/ steps :

- Duo needs to make sure that all security requirements are implemented. The Security Requirement tickets (part of the Epic/Story) needs to be moved up to “Ready for Security Verification” status.
- Developers are using Snyk in the IDE to scan their code before creating a PR

- At PR level, Snyk/Sonarqube is scanning (SAST, SCA, license violation) and enforces a hard gate in case of High/Critical vulnerabilities
- In case of High/Critical vulnerabilities, the responsible engineer is addressing the security vulnerability (should involve EM and/or Security team if needed)
- Once build phase is completed , PM/EM taggs the security team (Yash) in the comments letting him know about the readiness of the feature for security testing.

SG04 - Testing Phase

INPUT: Built feature/ flow as per the epic/story present in staging environment (ae02 /sa02). Security Requirements ticket in "Ready for Security Verification" status.

OUTPUT: Security requirements implementation is validated. No High/Critical security vulnerabilities raised and not solved

Activities/ steps :

- Security team creates a new story as part of Security Testing Business As Usual epic and adds the testing plan for the new epic/story. The security story created will be linked to the Engineering story/epic.
- Security team will review all "Security Requirement" tickets to validate the correct implementation of the committed security requirements.
- Security team will complete the security testing as per the plan and will mark completed the security story
- Any security findings will be tagged as part of the security story.
- All High/Critical identified security vulnerabilities will need to be fixed prior to promoting to production

SG05 - Deployment Phase

INPUT: Feature ready to be deployed

OUTPUT: Feature deployed on lower environment first, following production after

Activities/ steps :

- Snyk IaC scanning (where applicable - e.g. K8s code)-not in place today
- Tenable.io (Nessus) vulnerability assessment scanning

